PENSE-BÊTE · MÉTHODES ET GOUVERNANCE

Audit et Gouvernance des SI

04-90 CHAI - Guide d'audit des systèmes d'information, gouvernance, ITIL et COBIT — source : fiche de révision du module (gemma4, 03/11/2026 ; relu par Claude le 04/11/2026)

À RETENIR

1. La gouvernance des SI permet de contrôler et réguler le système en fixant des objectifs découlant de la stratégie de l'organisation.
2. Le schéma directeur est un plan stratégique pluriannuel de deux à six ans approuvé au plus haut niveau pour piloter le développement informatique.
3. La séparation des tâches impose que les développeurs n'accèdent pas à la production et que l'exploitation n'accède pas au développement.

Objet et organisation du guide

Notion	À retenir
Public et limites	Auditeurs internes **avertis** (pratiques d'audit > technique) ; points de contrôle **illustratifs**, pensés pour les **cycles en V**, moins adaptés à l'**agile** ; en **subsidiarité** des référentiels officiels.
Les trois parties	P1 : **facteurs clés de performance** et risques. P2 : **audits généralistes** et spécifiques SI. P3 : **tableaux de points de contrôle** et dictionnaire.

Enjeux et cadre stratégique du SI

Notion	À retenir
Alignement stratégique	Le SI soutient les **processus métier** et doit être **aligné** sur les objectifs stratégiques. Un SI adapté assure **performance**, **efficacité**, **efficience** et **maîtrise des risques**.
Cadre stratégique commun (État)	Circulaire du PM du **7 mars 2013** : 3 axes — **valeur** pour les utilisateurs, **efficience**, fonction SI **pilotée** ; + PSSI, urbanisation, **RGI**, **RGS**, accessibilité (ordonnance **8 déc. 2005**).

Facteurs clés d'un SI performant

Notion	À retenir
Implication direction	**Schéma directeur**, comités de pilotage (incidents, projets, budgets), tableaux de bord, portefeuille de projets, **cartographie** à jour.
Sécurité et conformité	**PSSI** (étude des risques, validée par la direction, mise à jour) ; **charte** d'utilisation (**idéalement** signée par tous) ; comités de sécurité réguliers.
Séparation des tâches	Développeurs **sans accès** à la production, exploitation **sans accès** au développement ; droits admin limités, tracés, revus ; droits **supprimés au départ**.
Projet et qualité	Vision claire, direction et utilisateurs impliqués, équipe dédiée, déploiement échelonné. Référentiels : **CMMI**, **ITIL**, **COBIT**, **ISO 27001**, **MAREVA**.

Audits spécifiques au domaine SI

Notion	À retenir
Audit de sécurité	Inventaire des actifs, évaluation des risques, processus de décision, pertinence du dispositif.
Audit qualité données	Chaque donnée a un **propriétaire unique** (création, mise à jour, suppression, protection, disponibilité). Risque : **duplication dans des fichiers locaux** (copie périmée échappe aux règles).
Audit de régularité	Mesure **écarts normes internes/publiques**. Recommandations : corriger pratiques **court terme** ou évoluer norme inadaptée **long terme** (ne pas contourner).

Audit du pilotage des SI

Notion	À retenir
Objectif et contrôles	**Maturité** informatique ; DSI rattachée à la DG ; comités stratégiques et de pilotage ; métiers en **MOA** ; schéma directeur mis à jour **chaque année**.

Audit de la production informatique

Notion	À retenir
Objectif et engagements	Disponibilité, intégrité, confidentialité, qualité de service ; **conventions de service** par application (indicateurs mesurés, tableaux de bord).
Organisation et livraisons	Production **indépendante** des études ; capacité, obsolescence, redondance suivies ; livraison contrôlée (**PV de recette**, tests d'intégration).

Audit des projets

Notion	À retenir
Instances de pilotage	**Comité de pilotage** (décision stratégique, arbitrages) · **Comité de projet** (opérationnel, MOE/prestataires) · **Comité des utilisateurs** (besoins, tests, réception).
Rôles, recette, évolutions	MOA/MOE et chef de projet (avec **autorité**) définis ; tests MOE puis **MOA**, **PV** de recette ; évolutions avec mesure d'impact ; bascule en production **tracée**.

Les marchés informatiques

Forme	Risques / Exigences
Forfait	protège le **prix** mais expose au risque de **dérive du calendrier** et de **périmètre trop restreint**
Forfait horaire	**très déconseillé** : fait porter le **risque économique au client** et expose au **prêt illicite de main-d'œuvre** et au **marchandage**
Infogérance et TMA	engagements de performance, pénalités, **réversibilité** (reprise du système par le client ou un tiers) ; la TMA ne doit pas camoufler du développement

ITIL, CAB et RACI (compléments hors guide du CHAI)

Notion	À retenir
ITIL et changements	**ITIL 4** (**PeopleCert**) : habilitation changements maîtrise **risques**. Types : **standards** (préautorisés), **normaux** (évalués) ou **urgents**.
Le CAB	**CAB** (Change Advisory Board) : évalue, priorise, planifie et conseille l'autorité. Réunit **métiers**, **production**, **études**, **sécurité** et **fournisseurs**. L'**ECAB** traite les changements **urgents**.
La matrice RACI	Répartit les responsabilités : **R**éalise, **A**pprouve, **C**onsulté, **I**nformé. **Un seul A** par ligne, responsable du résultat.

Pièges et confusions

- ⚠ Confondre ITIL (production) avec COBIT (gouvernance et contrôle interne)
- ⚠ Confondre le PCA (poursuite de l'activité pendant un sinistre) avec le PRA (reprise après un sinistre)
- ⚠ Croire que l'AMOA peut remplacer la MOA
- ⚠ Utiliser le forfait horaire dans les marchés informatiques
- ⚠ Confondre la fonction informatique avec la fonction d'information

Sigles et définitions

CHAI	Comité d'harmonisation de l'audit interne
ITIL	Référentiel de bonnes pratiques spécifique à la gestion de la production informatique
COBIT	Référentiel de gouvernance et de contrôle interne informatique
CMMI	Référentiel de maturité des développements informatiques avec des niveaux de 1 à 5
ISO 27001	Norme présentant les exigences en matière de sécurité informatique
SLA	Contrat ou convention de service formalisant un niveau de service négocié

Auto-test

1. Quelle est la durée d'un schéma directeur ?
2. Qui est le garant technique de la réalisation d'un projet ?
3. Quel référentiel traite de la maturité des développements ?
4. Qu'est-ce que la réversibilité ?
5. Combien de responsables 'A' (Approuve) peut-il y avoir par ligne dans une matrice RACI ?

Réponses : **1.** Deux à six ans · **2.** La MOE · **3.** CMMI · **4.** L'obligation pour un prestataire de permettre au client de reprendre son système ou de le confier à un tiers · **5.** Un seul

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.